

# Software Requirements Specification

## Jackfruit Phase-1 — Student Record System

Tanmay T A, PES1UG24CS492      Uttam B S, PES1UG24CS508  
Vibha Venkatesh Vasisht, PES1UG24CS526

Generated 2026-10-01

## Contents

|          |                                                         |          |
|----------|---------------------------------------------------------|----------|
| <b>1</b> | <b>Revision History</b>                                 | <b>2</b> |
| <b>2</b> | <b>1. Introduction</b>                                  | <b>3</b> |
| 2.1      | 1.1 Purpose . . . . .                                   | 3        |
| 2.2      | 1.2 Intended Audience and Reading Suggestions . . . . . | 3        |
| 2.3      | 1.3 Product Scope . . . . .                             | 3        |
| 2.4      | 1.4 References . . . . .                                | 3        |
| <b>3</b> | <b>2. Overall Description</b>                           | <b>3</b> |
| 3.1      | 2.1 Product Perspective . . . . .                       | 3        |
| 3.2      | 2.2 Product Functions . . . . .                         | 3        |
| 3.3      | 2.3 User Classes and Characteristics . . . . .          | 3        |
| 3.4      | 2.4 Operating Environment . . . . .                     | 4        |
| 3.5      | 2.5 Design and Implementation Constraints . . . . .     | 4        |
| 3.6      | 2.6 Assumptions and Dependencies . . . . .              | 4        |
| <b>4</b> | <b>3. External Interface Requirements</b>               | <b>4</b> |
| 4.1      | 3.1 User Interfaces . . . . .                           | 4        |
| 4.2      | 3.2 Software Interfaces . . . . .                       | 4        |
| 4.3      | 3.3 Communications Interfaces . . . . .                 | 4        |
| <b>5</b> | <b>4. Analysis Models</b>                               | <b>4</b> |
| <b>6</b> | <b>5. System Features</b>                               | <b>4</b> |
| 6.1      | 5.1 Onboarding . . . . .                                | 4        |
| 6.1.1    | 5.1.1 Description and Priority . . . . .                | 4        |
| 6.1.2    | 5.1.2 Stimulus/Response Sequences . . . . .             | 5        |
| 6.1.3    | 5.1.3 Functional Requirements . . . . .                 | 6        |
| 6.2      | 5.2 Edit Records . . . . .                              | 7        |
| 6.2.1    | 5.2.1 Description and Priority . . . . .                | 7        |
| 6.2.2    | 5.2.2 Stimulus/Response Sequences . . . . .             | 7        |
| 6.2.3    | 5.2.3 Functional Requirements . . . . .                 | 7        |
| 6.3      | 5.3 Mark Attendance (with constraints) . . . . .        | 7        |

|           |                                                          |           |
|-----------|----------------------------------------------------------|-----------|
| 6.3.1     | 5.3.1 Description and Priority . . . . .                 | 7         |
| 6.3.2     | 5.3.2 Stimulus/Response Sequences . . . . .              | 7         |
| 6.3.3     | 5.3.3 Functional Requirements . . . . .                  | 7         |
| 6.4       | 5.4 Mark Grades (with rubric) . . . . .                  | 8         |
| 6.4.1     | 5.4.1 Description and Priority . . . . .                 | 8         |
| 6.4.2     | 5.4.2 Stimulus/Response Sequences . . . . .              | 8         |
| 6.4.3     | 5.4.3 Functional Requirements . . . . .                  | 8         |
| 6.5       | 5.5 Retrieval . . . . .                                  | 8         |
| 6.5.1     | 5.5.1 Description and Priority . . . . .                 | 8         |
| 6.5.2     | 5.5.2 Stimulus/Response Sequences . . . . .              | 8         |
| 6.5.3     | 5.5.3 Functional Requirements . . . . .                  | 8         |
| 6.6       | 5.6 Role-Based Access . . . . .                          | 8         |
| 6.6.1     | 5.6.1 Description and Priority . . . . .                 | 8         |
| 6.6.2     | 5.6.2 Stimulus/Response Sequences . . . . .              | 9         |
| 6.6.3     | 5.6.3 Functional Requirements . . . . .                  | 10        |
| <b>7</b>  | <b>6. Other Nonfunctional Requirements</b>               | <b>12</b> |
| 7.1       | 6.1 Performance Requirements . . . . .                   | 12        |
| 7.2       | 6.2 Safety Requirements . . . . .                        | 12        |
| 7.3       | 6.3 Security Requirements . . . . .                      | 12        |
| 7.4       | 6.4 Software Quality Attributes . . . . .                | 12        |
| 7.5       | 6.3 Security Requirements . . . . .                      | 12        |
| 7.6       | 6.5 Business Rules . . . . .                             | 13        |
| <b>8</b>  | <b>7. Other Requirements</b>                             | <b>13</b> |
| <b>9</b>  | <b>Appendix A: Glossary</b>                              | <b>14</b> |
| <b>10</b> | <b>Appendix B: Field Layouts</b>                         | <b>14</b> |
| 10.1      | Student . . . . .                                        | 14        |
| <b>11</b> | <b>Appendix C: Requirement Traceability Matrix</b>       | <b>14</b> |
| <b>12</b> | <b>Appendix D: Stakeholder Discussion Log</b>            | <b>14</b> |
| 12.1      | Persona . . . . .                                        | 14        |
| 12.2      | Discussion 1 — Discovery Call (DATE) . . . . .           | 14        |
| 12.3      | Discussion 2 — Deployment & Constraints (DATE) . . . . . | 14        |
| 12.4      | Discussion 3 — Sign-off (DATE) . . . . .                 | 15        |

# 1 Revision History

| Name | Date | Reason For Changes | Version |
|------|------|--------------------|---------|
|      |      | Initial draft      | 0.1     |

Add a row every time a substantive change is made (not every typo fix). Keep this current — it's a required section.

## **2 1. Introduction**

### **2.1 1.1 Purpose**

TODO

### **2.2 1.2 Intended Audience and Reading Suggestions**

TODO

### **2.3 1.3 Product Scope**

TODO

### **2.4 1.4 References**

TODO

## **3 2. Overall Description**

### **3.1 2.1 Product Perspective**

TODO

### **3.2 2.2 Product Functions**

- Onboarding (student/staff registration)
- Edit records
- Mark attendance (with constraints)
- Mark grades (with rubric)
- Retrieval / search
- Role-based access control

### **3.3 2.3 User Classes and Characteristics**

Write Section 2.3 — User Classes and Characteristics for our Student Record System SRS.

Use the existing repository, official project guidelines, team workflow, and my finalized 5.1 Onboarding + 5.6 RBAC requirements as the source of truth.

Cover exactly these user classes: - Admin - Teacher - Student

For each, briefly describe: - What they can do in the system - Their access/permission level - Their expected technical proficiency - Any relevant characteristics or usage patterns

Keep it concise and consistent with our existing RBAC requirements. Do not introduce new roles or permissions.

Output ONLY the final Markdown content for Section 2.3, ready to paste into: docs/srs/markdown/03-overall-d

TODO

### 3.4 2.4 Operating Environment

TODO

### 3.5 2.5 Design and Implementation Constraints

TODO

### 3.6 2.6 Assumptions and Dependencies

TODO

## 4 3. External Interface Requirements

### 4.1 3.1 User Interfaces

TODO

### 4.2 3.2 Software Interfaces

TODO

### 4.3 3.3 Communications Interfaces

TODO

## 5 4. Analysis Models

TODO

## 6 5. System Features

### 6.1 5.1 Onboarding

#### 6.1.1 5.1.1 Description and Priority

**Description.** Onboarding is how user accounts are created in the Student Record System. An authenticated Admin creates Student and Teacher accounts and assigns each account a role. Self-registration is out of scope. The Admin never sets or knows the user's password. The user sets their own password through a secure initial-password setup, then logs in separately using their registered email address and password.

**Priority:** High. Every other feature needs an existing, authenticated account.

**Preconditions.** - A pre-seeded Admin account exists (created during initial system setup). - The Admin performing onboarding is authenticated.

**Inputs.**

| Account type            | Unique identifier | Other required fields                 |
|-------------------------|-------------------|---------------------------------------|
| Student                 | SRN               | Name, email, academic/program details |
| Teacher                 | Staff ID          | Name, email, department details       |
| Admin (pre-seeded only) | Admin ID          | Name, email, password                 |

The Admin also selects the role (Student or Teacher). Field lengths, data types and the final field list are defined in Appendix B.

**Assumptions and dependencies.** - What each role may do after onboarding is defined in Section 5.6. - The hashing algorithm, session handling, setup-credential validity period and delivery mechanism are defined in Section 6.3 (TBD). - Email verification is out of scope. - Identifier and email comparisons ignore letter case and leading/trailing whitespace.

### 6.1.2 5.1.2 Stimulus/Response Sequences

| #    | Stimulus (trigger)                                                                          | System validation                                                        | System response                                                                                                         |
|------|---------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| SR-1 | Admin submits a valid account-creation request with a unique identifier and email.          | Admin authenticated; required fields valid; identifier and email unique. | Account created as Active; password setup initiated; Admin sees a confirmation. No session is created for the new user. |
| SR-2 | Admin submits a request with a missing or invalid field.                                    | Field validation fails.                                                  | No account created; every failing field is identified; entered non-password values are retained.                        |
| SR-3 | Admin submits an SRN, Staff ID, Admin ID or email already in use.                           | Uniqueness check finds a match.                                          | Request rejected; existing account unchanged; error names the duplicated field.                                         |
| SR-4 | A non-Admin or unauthenticated user attempts account creation.                              | Authentication/role check fails.                                         | Access denied; no account created.                                                                                      |
| SR-5 | New user submits a valid password and matching confirmation using a valid setup credential. | Credential valid, unused, unexpired; password rules met.                 | Password hashed and stored; credential invalidated; user directed to log in separately.                                 |

| #    | Stimulus (trigger)                                                                                        | System validation                   | System response                                               |
|------|-----------------------------------------------------------------------------------------------------------|-------------------------------------|---------------------------------------------------------------|
| SR-6 | New user submits a password that breaks the rules, does not match, or uses an invalid/expired credential. | Password or credential check fails. | Nothing stored; message states what failed.                   |
| SR-7 | User tries to log in before setting a password.                                                           | No password set for the account.    | Login rejected with a generic authentication-failure message. |

### 6.1.3 5.1.3 Functional Requirements

- **REQ-ONB-001:** The system shall allow only an authenticated Admin to create accounts, and shall reject any other attempt with an access-denied message and no account created.
- **REQ-ONB-002:** The system shall provide no self-registration function, and shall provide a pre-seeded Admin account created during initial system setup (handling of its initial credential is specified in Section 6.3).
- **REQ-ONB-003:** The system shall require the Admin to select exactly one role (Student or Teacher) for each new account, and shall store the selected role with the account.
- **REQ-ONB-004:** For a Student account, the system shall require SRN, name, email and academic/program details (as defined in Appendix B).
- **REQ-ONB-005:** For a Teacher account, the system shall require Staff ID, name, email and department details (as defined in Appendix B).
- **REQ-ONB-006:** The system shall neither require nor accept a password from the Admin when creating a Student or Teacher account.
- **REQ-ONB-007:** The system shall trim leading and trailing whitespace from text inputs, and shall reject a request in which a required field is missing or blank, an email is not in a valid format (one “@” with non-empty parts and a “.” in the domain), or any value violates the limits in Appendix B.
- **REQ-ONB-008:** When validation fails, the system shall create no account, shall display an error message identifying every invalid or missing field, and shall retain the entered non-password values.
- **REQ-ONB-009:** The system shall ensure that no two accounts share the same SRN, Staff ID, Admin ID or email address (compared without regard to letter case), including when two requests are submitted simultaneously.
- **REQ-ONB-010:** When a submitted identifier or email duplicates an existing account, the system shall reject the request, leave the existing account unchanged, and display an error message that names the duplicated field and discloses no other data of the existing account.
- **REQ-ONB-011:** The system shall set a successfully created account to Active with no approval step, and shall record the creation time and the creating Admin.
- **REQ-ONB-012:** Upon successful account creation, the system shall initiate a secure initial-password setup through which the user sets their own password, and shall never reveal that password to the Admin or any other user.
- **REQ-ONB-013:** The system shall issue the setup credential as single-use, bound to one account and valid for a limited period (period and delivery mechanism TBD in Section 6.3).

- **REQ-ONB-014:** The system shall reject a setup credential that is used, expired or invalid, shall set no password, and shall inform the user that the credential is not valid.
- **REQ-ONB-015:** The system shall require the password to be entered twice with matching entries, to have at least 8 characters, and to contain at least one uppercase letter, one lowercase letter, one digit and one special character; otherwise it shall not store the password and shall state which rule was not met.
- **REQ-ONB-016:** The system shall store a password only as a salted, adaptive, one-way hash (algorithm defined in Section 6.3), and shall not store, log or display it in plaintext.
- **REQ-ONB-017:** Upon successful password setup, the system shall invalidate the setup credential, shall create no authenticated session, and shall direct the user to log in separately.
- **REQ-ONB-018:** The system shall use the registered email address as the login identifier, and shall reject login for an account whose password is not yet set with the same generic message used for incorrect credentials.
- **REQ-ONB-019:** Upon successful account creation, the system shall show the Admin a confirmation containing the new account's identifier, name and role, and no password, hash or setup credential.
- **REQ-ONB-020:** The system shall create an account atomically, leaving no partial account if any step fails, and shall show a generic error message that exposes no internal details when an unexpected error occurs.

## 6.2 5.2 Edit Records

### 6.2.1 5.2.1 Description and Priority

TODO

### 6.2.2 5.2.2 Stimulus/Response Sequences

TODO

### 6.2.3 5.2.3 Functional Requirements

- REQ-REC-1:
- REQ-REC-2:

## 6.3 5.3 Mark Attendance (with constraints)

### 6.3.1 5.3.1 Description and Priority

TODO

### 6.3.2 5.3.2 Stimulus/Response Sequences

TODO

### 6.3.3 5.3.3 Functional Requirements

- REQ-ATT-1:
- REQ-ATT-2:

## **6.4 5.4 Mark Grades (with rubric)**

### **6.4.1 5.4.1 Description and Priority**

TODO

### **6.4.2 5.4.2 Stimulus/Response Sequences**

TODO

### **6.4.3 5.4.3 Functional Requirements**

- REQ-GRD-1:
- REQ-GRD-2:

## **6.5 5.5 Retrieval**

### **6.5.1 5.5.1 Description and Priority**

TODO

### **6.5.2 5.5.2 Stimulus/Response Sequences**

TODO

### **6.5.3 5.5.3 Functional Requirements**

- REQ-RET-1:
- REQ-RET-2:

## **6.6 5.6 Role-Based Access**

### **6.6.1 5.6.1 Description and Priority**

**Description.** Role-Based Access Control (RBAC) decides which functions and records each authenticated user may use. Every account has exactly one role: Admin, Teacher or Student. The role is assigned at account creation (Section 5.1), and only an Admin can change it. Permissions are enforced in both the frontend and the backend, and the backend is the authoritative enforcement layer. Anything not explicitly permitted to a role is denied. Authentication (Section 5.1 and Section 6.3) establishes who the user is, and authorization (this section) decides what that user may do.

**Priority:** High. Features 5.2 to 5.5 read and modify student data and depend on correct authorization.

**Roles and permissions.**

| Role    | Permitted                                                                                                                                                                      | Scope boundary         | Not permitted                                                |
|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|--------------------------------------------------------------|
| Admin   | Create, update, deactivate Student and Teacher accounts; assign and change roles; view and manage student records, attendance and grades; view all Teacher and Student records | All relevant records   | None defined in this version                                 |
| Teacher | View assigned students; mark and edit attendance and enter and edit grades for assigned students; view academic records of assigned students                                   | Assigned students only | Students outside the assignment; account and role management |
| Student | View own profile, attendance, grades and academic records                                                                                                                      | Own records only       | Other students' records; modifying own grades or attendance  |

**Assumptions and dependencies.** - Attendance rules (Section 5.3) and grading rules (Section 5.4) apply in addition to RBAC. - Session/token mechanism, audit-log retention and who may view the audit log are defined in Section 6.3 (TBD). - How a Teacher is assigned to a Student is TBD. RBAC only requires that the assignment exists. - TBD in this version: whether an Admin may deactivate their own or the last remaining Admin account, and how records and assignments are handled when an account's role changes.

### 6.6.2 5.6.2 Stimulus/Response Sequences

| #    | Stimulus (trigger)                                                                                     | System validation                                                    | System response                                     |
|------|--------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|-----------------------------------------------------|
| SR-1 | Admin requests an Admin-permitted function (e.g. view any record, edit grades, deactivate an account). | Session valid; account Active; role is Admin.                        | Request processed and result shown.                 |
| SR-2 | Teacher requests an assigned student's record or attendance/grade function.                            | Session valid; role is Teacher; student is assigned to this Teacher. | Request processed, subject to Sections 5.3 and 5.4. |

| #    | Stimulus (trigger)                                                                            | System validation                                               | System response                                                              |
|------|-----------------------------------------------------------------------------------------------|-----------------------------------------------------------------|------------------------------------------------------------------------------|
| SR-3 | Teacher requests a student who is not assigned to them.                                       | Student not in this Teacher's assignment.                       | "Access Denied/Unauthorized"; no data returned; attempt logged.              |
| SR-4 | Student requests their own profile, attendance, grades or academic records.                   | Session valid; role is Student; record belongs to this Student. | Record displayed read-only.                                                  |
| SR-5 | Student requests another student's record, or tries to modify their own grades or attendance. | Record not owned, or modification not permitted for Student.    | "Access Denied/Unauthorized"; data unchanged; attempt logged.                |
| SR-6 | Any user requests a function not permitted for their role (e.g. Teacher changes a role).      | Function not in the role's permission set.                      | "Access Denied/Unauthorized"; no change; attempt logged.                     |
| SR-7 | Admin changes a user's role.                                                                  | Requester is Admin; account exists; new role is valid.          | Role updated and effective immediately; change recorded; confirmation shown. |
| SR-8 | Deactivated user tries to log in or uses an existing session.                                 | Account status is Deactivated.                                  | Request rejected; no data returned; no new session created.                  |
| SR-9 | Unauthenticated user, or user with an expired/invalid session, requests a protected function. | Authentication check fails.                                     | Request rejected; user directed to log in; no data returned.                 |

### 6.6.3 5.6.3 Functional Requirements

- **REQ-RBAC-001:** The system shall support exactly three roles (Admin, Teacher and Student) and shall associate every account with exactly one role at all times.
- **REQ-RBAC-002:** The system shall deny any function or record access that is not explicitly permitted to the requesting user's role.
- **REQ-RBAC-003:** The backend shall verify authentication and authorization (role and record scope) on every protected request before processing it, regardless of any frontend check.
- **REQ-RBAC-004:** The frontend shall display only the functions permitted to the logged-in user's role.
- **REQ-RBAC-005:** The system shall associate the authenticated user's role with the authenticated session, check it on every protected request, and not accept a client-supplied role, identity or ownership claim in its place.
- **REQ-RBAC-006:** The system shall deny a protected request whose session is missing,

expired, invalid or inconsistent with the stored account, and for an unauthenticated user shall direct the user to log in without returning protected data.

- **REQ-RBAC-007:** The system shall allow an Admin to create, update and deactivate Student and Teacher accounts, and to assign and change roles.
- **REQ-RBAC-008:** The system shall allow an Admin to view and manage the records, attendance and grades of all students (subject to Sections 5.3 and 5.4) and to view all Teacher records.
- **REQ-RBAC-009:** The system shall allow a Teacher to view the list of students assigned to them, to mark and edit attendance and enter and edit grades for those students (subject to Sections 5.3 and 5.4), and to view those students' relevant academic records.
- **REQ-RBAC-010:** The system shall deny a Teacher any read or write access to a student who is not assigned to that Teacher, and shall evaluate the assignment on every request so a change takes effect on the next request (assignment mechanism TBD).
- **REQ-RBAC-011:** The system shall deny a Teacher the creation, update and deactivation of accounts and the assignment or change of roles.
- **REQ-RBAC-012:** The system shall allow a Student to view their own profile, attendance, grades and academic records.
- **REQ-RBAC-013:** The system shall deny a Student any access to another student's records, any modification of their own grades or attendance, and any Teacher or Admin function.
- **REQ-RBAC-014:** When a request is denied for lack of authorization, the system shall return a clear "Access Denied/Unauthorized" message, process no part of the request, leave data unchanged, and give the same response for a nonexistent record as for an unauthorized one.
- **REQ-RBAC-015:** When an authorization check cannot be completed because of an internal error, the system shall deny the request and show a generic error message that exposes no internal details.
- **REQ-RBAC-016:** The system shall allow only an Admin to assign or change a role, shall accept only Admin, Teacher or Student as the new role, and shall reject a role change for a nonexistent account with an error message.
- **REQ-RBAC-017:** The system shall apply a role change immediately, so that every later protected request (including from existing sessions) is authorized against the new role, shall keep exactly one role on the account, and shall record the affected account, previous role, new role, Admin and time.
- **REQ-RBAC-018:** The system shall allow only an Admin to deactivate an account, and shall invalidate all active sessions of that account immediately.
- **REQ-RBAC-019:** The system shall reject login by a deactivated account without creating a session, and shall deny every protected request made with a session of a deactivated account.
- **REQ-RBAC-020:** The system shall log every denied protected request and every failed authentication or session validation on a protected request (recording time, user identity and role if known, requested function or record, and outcome), shall not record passwords, hashes or session secrets in the log, and shall allow no role to modify or delete log entries through application functions.
- **REQ-RBAC-046:** The system shall not record passwords, password hashes or session secrets in the audit log.
- **REQ-RBAC-047:** Audit-log retention period and which roles may view the log are TBD and defined in Section 6.3.

## 7 6. Other Nonfunctional Requirements

### 7.1 6.1 Performance Requirements

TODO

### 7.2 6.2 Safety Requirements

TODO — likely N/A or brief for this project type, but don't just delete the section.

### 7.3 6.3 Security Requirements

TODO

### 7.4 6.4 Software Quality Attributes

### 7.5 6.3 Security Requirements

Security requirements for authentication, password protection, session handling, authorization enforcement, and protection of student data. They complete the items that Sections 5.1 and 5.6 defer to this section: hashing algorithm, session mechanism, setup-credential rules, and audit-log rules. Functional behaviour of onboarding and role-based access is in Sections 5.1 and 5.6 and is not repeated here. The numeric values below (for example timeouts and the lockout threshold) are team decisions for this project; the other numbers are reasonable defaults for a student record system.

**Scope note.** Password change and password reset are not part of this version. Email is used only to deliver the initial-password setup credential (Section 5.1).

**Authentication and password protection - REQ-SEC-001:** The system shall authenticate a user only by verifying the submitted password against the stored hash of the account matching the submitted registered email, and shall create a session only when verification succeeds for an Active account whose password has been set. - **REQ-SEC-002:** The system shall return the same generic authentication-failure message, with no indication of which part was wrong, for an unknown email, an incorrect password, a deactivated account, a locked account, and an account whose password is not yet set. - **REQ-SEC-003:** The system shall hash passwords with bcrypt using a unique random salt per password and a cost factor of at least 10, and shall verify passwords only by comparing against this hash. - **REQ-SEC-004:** The system shall never return, display, log or export a password or password hash in any response, screen, report or log entry. - **REQ-SEC-005:** The system shall lock login for an account for 15 minutes after 5 consecutive failed login attempts, shall reset the failure count after a successful login, and shall show the generic message of REQ-SEC-002 while the lock is active. - **REQ-SEC-006:** The system shall generate each initial-password setup credential with a cryptographically secure random generator and at least 128 bits of randomness, deliver it to the user's registered email address, make it valid for 24 hours and for one use only, and invalidate it if the account is deactivated. - **REQ-SEC-007:** The system shall take the pre-seeded Admin's initial credential from the initial system setup, apply the password rules of REQ-ONB-015 and the hashing of REQ-SEC-003 to it, and shall not hard-code it in source code or commit it to the project repository.

**Session and token security - REQ-SEC-008:** The system shall keep session state on the server, shall give the client only an opaque session identifier generated with a cryptographically

secure random generator and containing no role or personal data, shall issue a new identifier at every successful login, and shall obtain the user's role and account status from the server's stored data on every protected request. - **REQ-SEC-009:** The system shall expire a session after 30 minutes without activity or 8 hours after login, whichever comes first, and shall invalidate the session on the server immediately when the user logs out; an expired or logged-out session shall be rejected on every protected request. - **REQ-SEC-010:** The system shall carry all client-server communication over an encrypted connection, shall reject or redirect unencrypted requests, and shall send the session identifier only over that connection and in a form not readable by client-side scripts.

**Authorization enforcement and record confidentiality - REQ-SEC-011:** The system shall perform all authorization checks in the backend in one common enforcement layer through which every protected request passes, so that a protected function is unreachable without passing the checks of REQ-RBAC-003, and a newly added protected function is denied until a role permission is defined for it. - **REQ-SEC-012:** The system shall apply the access boundaries of Section 5.6 to every way of obtaining student data, including retrieval, search, lists, reports and exports, so that a result contains only records the requesting user is authorized to see.

**Input validation and protection against common attacks - REQ-SEC-013:** The system shall validate the type, length and format of every user-supplied input in the backend, regardless of any frontend validation, and shall reject invalid input without processing it. - **REQ-SEC-014:** The system shall never interpret user-supplied input as part of a query or command (it shall be passed to the data store only as bound parameters), and shall encode user-supplied data when displaying it so that it cannot run as script in the user's browser. - **REQ-SEC-015:** The system shall reject any state-changing request that does not carry a valid anti-forgery token tied to the user's session.

**Secure error handling and audit logging - REQ-SEC-016:** In every feature, the system shall show only generic error messages that contain no stack traces, file paths, query text, or other internal details, and shall record such details only in server-side logs. - **REQ-SEC-017:** In addition to the events required by REQ-RBAC-020, the system shall log successful and failed logins, account lockouts, account creations, role changes and account deactivations, each with time, acting user, affected account and outcome; the log shall be retained for at least 1 year and shall be viewable only by Admins, read-only.

**Data protection and security validation - REQ-SEC-018:** The system shall use student and user data only within the Student Record System, shall not disclose it to third parties, and shall not include student records in any email. - **REQ-SEC-019:** The project's continuous integration shall run static code analysis, and a release shall not be made while high-severity security findings remain unresolved. TODO

## 7.6 6.5 Business Rules

TODO

## 8 7. Other Requirements

TODO

## 9 Appendix A: Glossary

| Term    | Definition |
|---------|------------|
| Student |            |
| Section |            |
| Term    |            |
| Rubric  |            |

## 10 Appendix B: Field Layouts

### 10.1 Student

| Field | Length | Data Type | Description | Is Mandatory |
|-------|--------|-----------|-------------|--------------|
|       |        |           |             |              |

## 11 Appendix C: Requirement Traceability Matrix

| Sl. No | Requirement ID | Brief Description | Architecture Reference | Design Reference | Code File Reference | Test Case ID | System Test Case ID |
|--------|----------------|-------------------|------------------------|------------------|---------------------|--------------|---------------------|
|        |                |                   |                        |                  |                     |              |                     |

## 12 Appendix D: Stakeholder Discussion Log

### 12.1 Persona

**Name / Role:** TODO — e.g. “Dr. [Name], Vice-Principal (Academics)” **Context:** TODO — one line on the institution and why they need this system.

### 12.2 Discussion 1 — Discovery Call (DATE)

**Topics covered:** initial scope, user roles, must-have features.

**Q:** TODO **A:** TODO

**Q:** TODO **A:** TODO

**Decisions made:** - TODO

### 12.3 Discussion 2 — Deployment & Constraints (DATE)

**Topics covered:** self-hosted vs. cloud, budget, expected concurrent users, data sensitivity / retention.

**Q:** Should this be cloud-hosted or self-hosted? **A:** TODO — record the reasoning, not just the conclusion.

**Q:** What's the expected scale (students, concurrent users)? **A:** TODO

**Q:** Any data privacy or retention constraints? **A:** TODO

**Decisions made:** - Deployment model: TODO - Tech stack: TODO

#### **12.4 Discussion 3 — Sign-off (DATE)**

**Topics covered:** final scope confirmation, any descoped features.

**Q:** TODO **A:** TODO

**Decisions made:** - TODO